Allegato Tecnico e Fornitori - Piazza 3.0

Documento di secondo livello – Integrazione all'Informativa sulla Privacy

Ultimo aggiornamento: 21 Marzo 2026

1. Elenco dei Fornitori e Responsabili del Trattamento

Ai sensi dell'art. 28 del GDPR, l'**Associazione di Promozione Sociale (APS) Piazza 3.0** si avvale di partner tecnologici selezionati per l'erogazione dei propri servizi. Tali soggetti agiscono in qualità di **Responsabili del Trattamento**:

Fornitore	Servizio	Sede Legale	Finalità
Tally BV	Tally.so	Belgio (UE)	Raccolta dati di iscrizione: dati anagrafici, documenti di identità e firme
Salesforce (Heroku)	PaaS Hosting	USA	Hosting database e applicazioni web, log di sicurezza
Amazon Web Services (AWS)	Infrastruttura	USA	Infrastruttura fisica dei server Heroku, log di sicurezza
Google LLC	Google Workspace	USA	Archiviazione Registro Soci

2. Trasferimento Dati Extra-UE (USA)

I dati personali ospitati sui server di **Heroku/Salesforce (AWS)** e **Google** sono trasferiti negli **Stati Uniti d'America (USA)**. Tale trasferimento è lecito e sicuro in virtù di:

- **Decisione di Adeguatezza:** tutti i fornitori coinvolti sono certificati e iscritti nella Data Privacy Framework List (**EU-U.S. Data Privacy Framework**).

- **Garanzie Accessorie:** ove necessario, il trattamento è regolato dalle *Standard Contractual Clauses* (SCC) fornite dai partner per garantire un livello di protezione equivalente a quello europeo.

3. Specifiche Tecniche di Sicurezza

L'Associazione adotta misure tecnico-organizzative per prevenire accessi non autorizzati e data breach:

- **Cifratura in transito:** tutti i dati scambiati tra l'utente e la piattaforma sono protetti dal protocollo **TLS (HTTPS)**.
- **Autenticazione Amministrativa:** l'accesso alle console di gestione (Heroku Dashboard, Google Sheets, Tally) è protetto da **Autenticazione a due fattori (2FA)** obbligatoria per tutti gli amministratori.
- **Isolamento dei Dati:** il database di produzione è separato dagli ambienti di sviluppo e di testing.

4. Sistema di Autenticazione (JWT tramite Cookie di Sessione)

La piattaforma gestisce l'autenticazione degli utenti tramite **JSON Web Tokens (JWT)**. A differenza delle implementazioni standard che memorizzano il token nello storage del browser, la nostra architettura adotta misure di sicurezza avanzate:

- **Modalità di memorizzazione:** il JWT non viene salvato né nel *LocalStorage* né nel *SessionStorage* (aree accessibili via JavaScript). Viene invece trasmesso e conservato esclusivamente come **cookie di sessione**, denominato app.sid.
- **Ambito di applicazione:** il cookie è limitato al dominio api.piazzatrepuntozero.it con percorso specifico path=/api.
- **Misure di Sicurezza del Cookie:**
    - **httpOnly=true:** impedisce a qualsiasi script lato client (JavaScript) di accedere al token, riducendo il rischio di furto tramite attacchi XSS.
    - **Secure=true:** garantisce che il token venga trasmesso esclusivamente su connessioni cifrate HTTPS.
    - **Nessuna memorizzazione sul server:** il server non mantiene una "sessione" aperta in memoria, ma valida la firma digitale del token a ogni richiesta, minimizzando l'impatto di eventuali attacchi lato server.

5. Log di Sistema e Manutenzione (Dati Effimeri)

Per motivi di sicurezza, monitoraggio delle prestazioni e prevenzione di abusi (es. attacchi di tipo Denial of Service), l'infrastruttura **Heroku** acquisisce log tecnici in tempo reale. In conformità al principio di minimizzazione dei dati, la gestione dei log segue queste regole:

- **Natura Effimera (Logplex):** il sistema di gestione log di **Heroku** (**Logplex**) non è configurato per l'archiviazione a lungo termine. I log sono consolidati in un buffer limitato (solitamente le ultime 1.500 righe di attività) e hanno una persistenza massima teorica di **7 giorni**.
- **Cancellazione Automatica:** data la natura della piattaforma, i log più vecchi vengono sovrascritti dai nuovi quasi istantaneamente o eliminati definitivamente dal sistema entro una settimana, senza alcuna persistenza su database a lungo termine.
- **Dati Registrati:** i log contengono informazioni tecniche quali indirizzo IP, pagine visitate, timestamp della richiesta e tipo di browser (user-agent). Tali dati sono utilizzati esclusivamente per garantire la stabilità del servizio e non vengono utilizzati per identificare o profilare gli utenti per finalità diverse dalla sicurezza informatica.
- **Assenza di Log Drains Esterni:** l'Associazione non utilizza servizi di archiviazione log persistenti di terze parti (come Papertrail o Splunk), garantendo che i dati tecnici di navigazione rimangano volatili e non archiviati permanentemente.